

Compass — A Private Eligibility Firewall on oG

Bounded disclosure for vulnerable migrant workers

Stephen Sookra · stephensookra@gmail.com

May 2026 · oG APAC Hackathon Track 5

Abstract

Compass is a private eligibility firewall. A vulnerable migrant worker proves she qualifies for a service — free legal aid, shelter intake, public hospital care — through an autonomous agent. The clinic learns a bucketed timestamp and a cryptographic commitment, **and nothing else**. The agent runs in a TEE (Phala dstack TDX) on oG; the receipt is a non-identifying event on oG Chain. Even under a subpoena, the clinic cannot disclose what it never held. We deploy on oG Galileo testnet today; mainnet (Aristotle) deploy is one configuration flip away once funded.

Live demo: <https://app-psi-pied.vercel.app> · Repo: <https://github.com/StephenSook/Compass-OG->.

Problem

In Hong Kong, ~340,000 Foreign Domestic Helpers (FDHs) live and work under contract terms that bind their visa to their employer. Asking a clinic for free legal aid traditionally requires handing over passport + HKID + employment contract — i.e., the same documents an abusive employer would need to retaliate via the 14-day rule. Maria, our composite persona, should be able to prove “I’m an FDH in HK with an open employment dispute” without disclosing **who** she is.

Compass treats eligibility as a predicate that can be evaluated *over* encrypted credentials inside a TEE, with only a binary outcome (`eligible: true/false`) plus a 15-minute-bucketed timestamp emitted on-chain. Maria’s identity, employer, document images, and full claim values never leave her device.

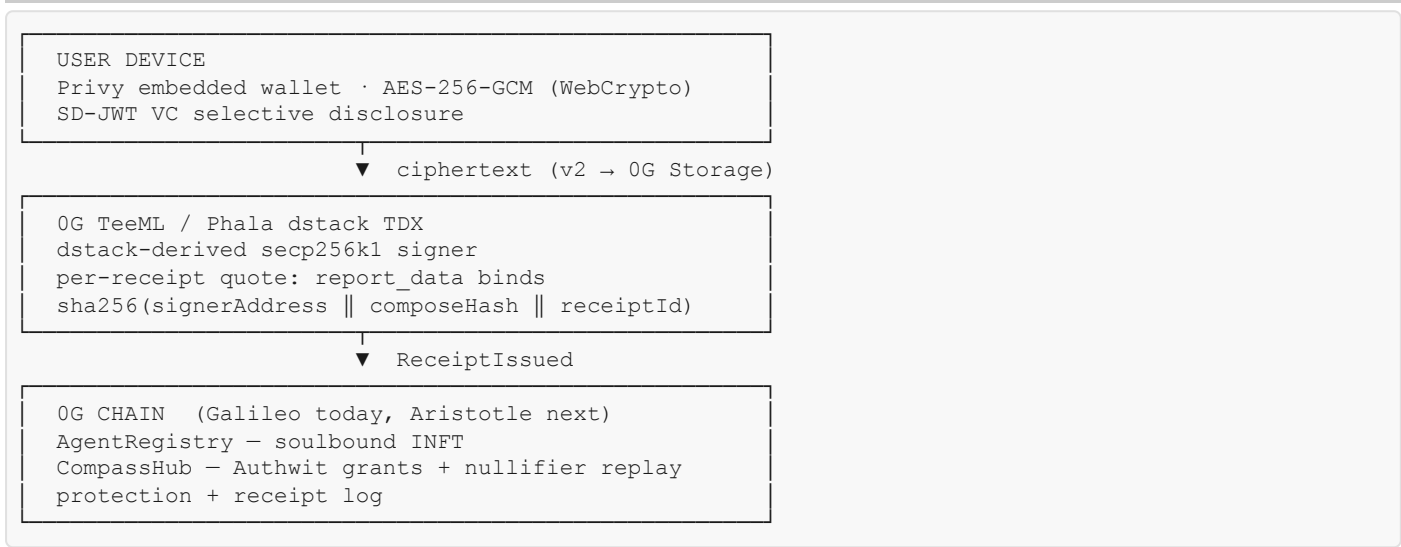
Threat Model

We defend against four adversaries:

1. **Curious clinic** — sees only the receipt event; cannot derive identity.
2. **Subpoena** — PDPO §57 disclosure orders reach exactly the receipt log. The “what’s there” surface is the load-bearing privacy property.
3. **Mempool watcher** — can observe `consumeGrantAndIssueReceipt` calldata. Cannot forge the EIP-712 grant signature; can grief by front-running the receiptId (documented as v1 limit; v2 derives receiptId in-contract).
4. **Compromised provider relay** — server-held key calls the contract on Maria’s behalf. The contract enforces `signer == ownerOf(agentTokenId)`, so a compromised relay cannot mint receipts against agents it doesn’t own. v2 moves the relay into the same TEE that signs receipts.

We do **not** defend against coercion, deniable encryption, statistical re-identification at small population sizes, or full Intel DCAP quote verification done on-chain (gas-prohibitive; off-chain via the `verify-receipt` CLI).

Architecture



Four oG layers: Compute (TEE), Chain (registry + receipts), Storage (v2: ciphertext bundles), Identity (soulbound agent INFT).

Protocol

The cryptographic chain a third-party verifier reproduces with one CLI command (`npm run verify-receipt`):

1. **Issue.** `/api/issue` Ed25519-signs an SD-JWT VC with HELP-fixture claims (`is_FDH_in_HK`, `has_pending_case`, `employment_active`, `residency`). Issuer key in env (v2 → enclave).
2. **Encrypt.** Browser AES-256-GCM with a non-extractable per-device key in IndexedDB. Plaintext SD-JWT VC never persists in localStorage.
3. **Grant.** Maria's Privy embedded wallet signs an EIP-712 `Grant` typed message: `{agentTokenId, policyId, provider, nonce, expiry, nullifier}`. Domain: `Compass v1` + `chainId` + `verifyingContract`.
4. **Consume + issue receipt.** `/api/consume` recovers the agent owner from the grant signature, computes `agentIdCommitment = keccak256(abi.encode(agentTokenId, owner))` matching the on-chain encoding, calls the live Phala TEE for an RA-quote-bound `attestationDigest`, and submits `consumeGrantAndIssueReceipt(grant, sig, receipt)` from the provider relayer wallet.
5. **Verify.** `ReceiptIssued` emits `{receiptId, policyId, nullifier, agentIdCommitment, resultHash, expiry, attestationDigest, timestampBucket}`. The verifier:
 - a. Re-derives `attestationDigest = sha256(canonicalize(receipt))`.
 - b. ECDSA-recovers the receipt-signer from the signature on that digest; matches the TEE-registered `ethAddress`.
 - c. Confirms `receipt.quoteCommitment = sha256(perReceiptQuoteHex)`.
 - d. Confirms the TDX quote's `report_data` field binds `sha256(signerAddress || composeHash || receiptId)` — defeats archived-quote replay.
 - e. Confirms the recovered `composeHash` matches the trust anchor pinned in `docs/notes/phala-deployment.md`.

When all five hold, the receipt is verified against the TEE attestation. A separate `compass-eligibility-check` skill packages this for ecosystem agents.

Honest Limits (v1)

We disclose what is mocked, stubbed, or downgraded — judges should read this before forming first impressions. Full version at `docs/honest-limits.md`. Highlights:

- **On-chain `verifyAttestation` is stubbed.** Real TDX RA quote verification (cert chain + ECDSA + 4KB quote) is gas-prohibitive on-chain. Off-chain verification via the `verify-receipt` CLI is the honest substitute.
- **Caller-supplied `receiptId` DoS.** A mempool watcher can grief by front-running with a duplicate `receiptId`. v2 fix is in-contract derivation. Single-actor demo doesn't bite v1.
- **SD-JWT VC `cnf` non-standard.** v1 stamps the EVM address; v2 emits the standards-compliant `cnf: { jwk }` shape derived from Privy's embedded wallet.
- **Trust list governance is owner-managed.** v2 needs DAO governance for cross-issuer threshold trust.
- **Provider relayer key in env.** v2 moves it into the same TEE that signs receipts.

Roadmap

v1.5 (June 2026): Aristotle mainnet deploy. Browser-side oG Storage ciphertext upload. Standards-compliant `cnf: { jwk }` emission.

v2 (Q3 2026): In-contract `receiptId` derivation. Provider relayer inside the TEE. Per-NGO provider keys (HELP, Bethune House, MFMW each hold their own). Trust list DAO governance.

v3 (later): Cross-chain receipt portability. Multi-policy composition (one grant covers a bundle of services). Cross-issuer threshold trust. Localized client (Tagalog, Indonesian, Cantonese, Bahasa Malaysia).

References

- Repository: <https://github.com/StephenSook/Compass-OG->
- Live demo: <https://app-psi-pied.vercel.app>
- Architecture page: <https://app-psi-pied.vercel.app/about>
- Subpoena scene: <https://app-psi-pied.vercel.app/clinic/subpoena>
- TEE deployment evidence: `docs/notes/phala-deployment.md`
- Threat model: `docs/honest-limits.md`
- Skill package: `skills/compass-eligibility-check/SKILL.md`
- AgentRegistry on Galileo: `0x461eda452ffAF43c674ef42BdcccFd6B8e13C2D8`
- CompassHub on Galileo: `0x60BbE5fcA6D23f7d25142E721258c641b45A7c3b`

NGO inspirations: HELP for Domestic Workers, Bethune House Migrant Women's Refuge, Mission for Migrant Workers (HK). The personas in this work are composites; no NGO has reviewed or endorsed this prototype.

